

Tutorial using sonarqube from local project & local laptop

This scenario will be fit in from developers review that code for checking the security before merge to main branch

1. Open Sonarqube and create local project

Projects

Issues

Rules

Quality Profiles

Quality Gates

Administration

More ▾

1 of 2

Create a local project

Project display name * ⓘ

testing-fincore.backend

Project key * ⓘ

testing-fincore.backend

Main branch name *

uat-mcf-r2

The name of your project's default branch [Learn More](#) ⓘ

Cancel

Next

testing-fincore.backend

Bind project

uat-mcf-r2 ⓘ

Overview

Issues

Security Hotspots

Code

Measures

Activity

Project Settings ▾

Project Info

Analysis Method

Use this page to manage and set-up the way your analyses are performed.

How do you want to analyze your repository?

With Jenkins

With GitHub Actions

With Bitbucket Pipelines

With GitLab CI

With Azure Pipelines

Other CI

SonarQube Community Build integrates with your workflow no matter which CI tool you're using.

Locally

Use this for testing or advanced use-case. Other modes are recommended to help you set up your CI environment.

2. Generate token and keep it for the next steps

Analysis Method / Locally

Analyze your project

We initialized your project on SonarQube Community Build, now it's up to you to launch analyses!

1 Provide a token

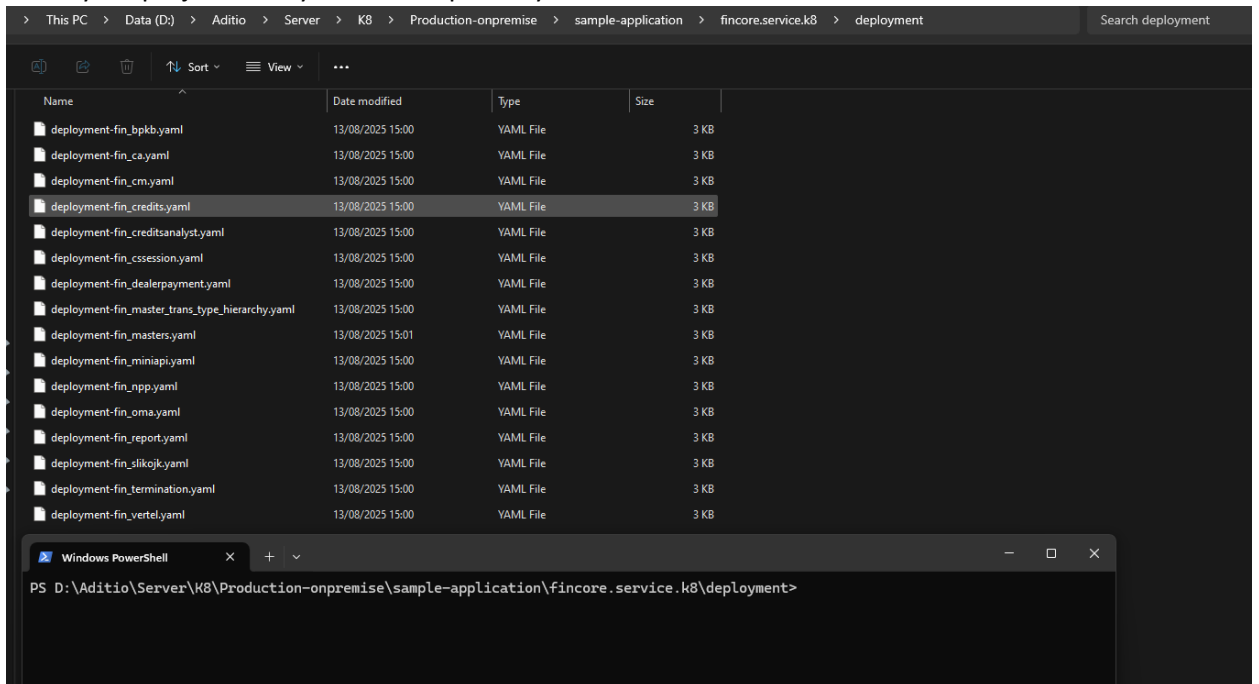
Analyze "testing-fincore.backend": `sqp_3fdedd6ea11d8bc2a7d328b13bfc8c87e13a43bf` 

The token is used to identify you when an analysis is performed. If it has been compromised, you can revoke it at any point in time in your [user account](#) .

Continue

2 Run analysis on your project

3. Clone your project from your code repository

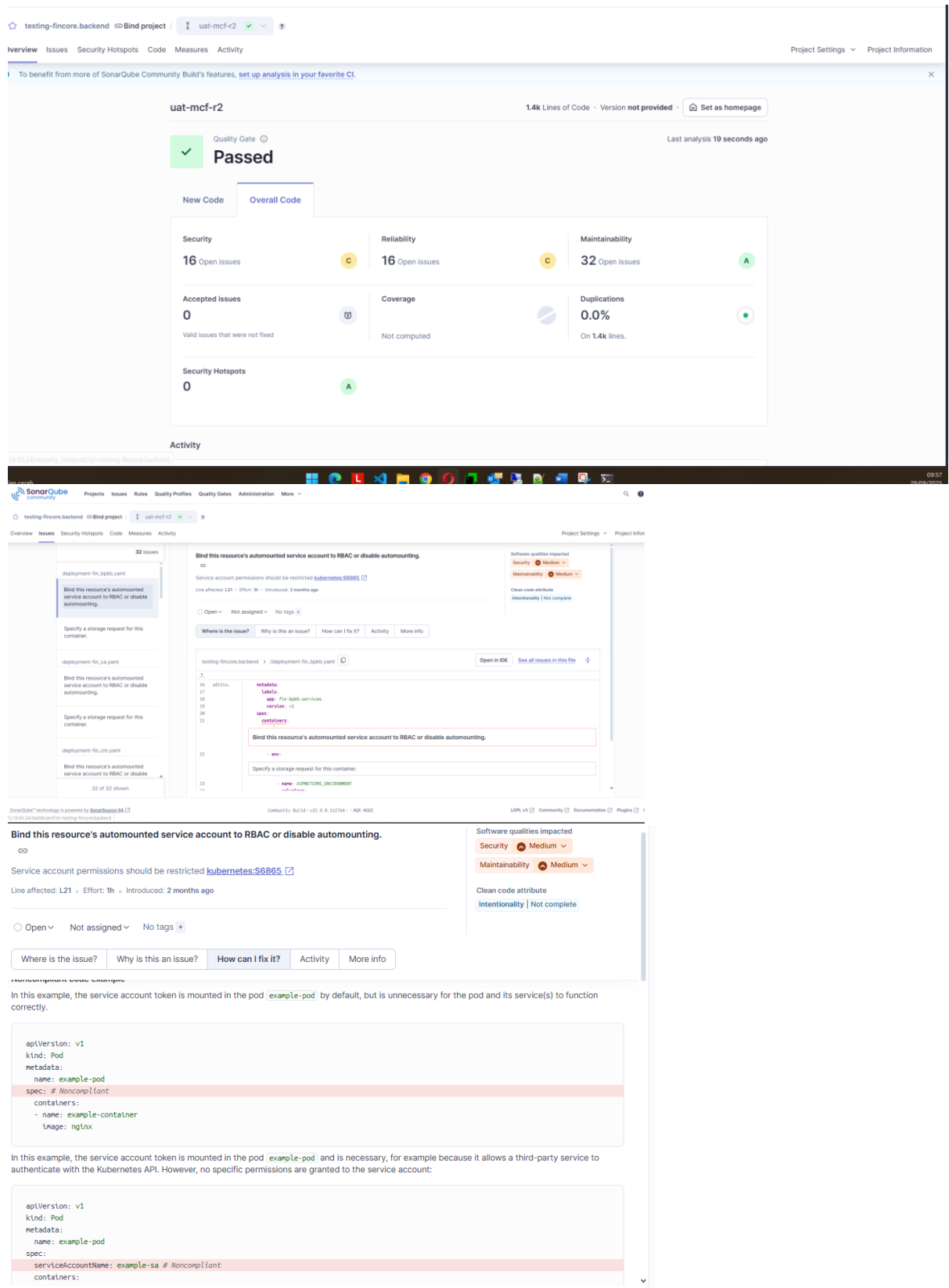


The screenshot shows a Windows File Explorer window with the path `This PC > Data (D:) > Aditio > Server > K8 > Production-onpremise > sample-application > fincore.service.k8 > deployment`. The search bar contains `Search deployment`. The file list shows several YAML files, including `deployment-fin_bpkb.yaml`, `deployment-fin_ca.yaml`, `deployment-fin_cm.yaml`, `deployment-fin_credits.yaml`, `deployment-fin_creditsanalyst.yaml`, `deployment-fin_cssession.yaml`, `deployment-fin_dealerpayment.yaml`, `deployment-fin_master_trans_type_hierarchy.yaml`, `deployment-fin_masters.yaml`, `deployment-fin_miniapi.yaml`, `deployment-fin_npp.yaml`, `deployment-fin_oma.yaml`, `deployment-fin_report.yaml`, `deployment-fin_slkoj.yaml`, `deployment-fin_termination.yaml`, and `deployment-fin_vertel.yaml`. A Windows PowerShell terminal window is open in the foreground, showing the command `PS D:\Aditio\Server\K8\Production-onpremise\sample-application\fincore.service.k8\deployment>`.

4. **Make sure you have a sonar-scanner**, and run the sonar-scanner for scanning your project in working directory

```
PS D:\Aditio\Server\K8\Production-onpremise\sample-application\fincore.service.k8\deployment>
PS D:\Aditio\Server\K8\Production-onpremise\sample-application\fincore.service.k8\deployment> sonar-scanner.bat -D"sonar.projectKey=testing-fincore.backend" -D"sonar.sources=." -D"sonar.host.url=http://[redacted]"
-D"sonar.token=sqp_3fdedd6ea11d8bc2a7d328b13bfc8c87e13a43bf"
09:57:25.089 INFO Scanner configuration file: D:\Aditio\Source\Sonarqube\sonar-scanner-7.2.0.5079-windows-x64\bin\.\conf\sonar-scanner.properties
09:57:25.018 INFO Project root configuration file: NONE
09:57:25.041 INFO SonarScanner CLI 7.2.0.5079
09:57:25.056 INFO Windows 11 10.0 amd64
09:57:27.482 INFO Communicating with SonarQube Community Build 25.9.0.112764
09:57:27.490 INFO JRE provisioning: os[windows], arch[amd64]
09:57:29.359 INFO Starting SonarScanner Engine...
09:57:29.361 INFO Java 17.0.13 Eclipse Adoptium (64-bit)
09:57:31.178 INFO Load global settings
09:57:31.363 INFO Load global settings (done) | time=185ms
09:57:31.372 INFO Server id: 1D744697-A2mAL9eUgSCXCHyQ1VP
09:57:31.384 INFO Loading required plugins
09:57:31.385 INFO Load plugins index
09:57:31.406 INFO Load plugins index (done) | time=110ms
09:57:31.406 INFO
```

5. After scanning, sonar-scanner will be sent the report analysis to sonarqube website, you can check the issues from your code and you will get the best recommended to fix your code based on that issues.



testing-fincore.backend @ Bind project / uat-mcf-r2

Overview Issues Security Hotspots Code Measures Activity

To benefit from more of SonarQube Community Build's features, set up analysis in your favorite CI.

uat-mcf-r2 1.4k Lines of Code · Version not provided · Set as homepage

Quality Gate **Passed** Last analysis 19 seconds ago

New Code Overall Code

Metric	Value	Grade
Security	16 Open issues	C
Reliability	16 Open issues	C
Maintainability	32 Open issues	A
Accepted issues	0	
Coverage	Not computed	
Duplications	0.0% On 1.4k lines.	
Security Hotspots	0	A

Activity

32 issues

Bind this resource's automated service account to RBAC or disable automounting.

Service account permissions should be restricted to [kubernetes:S6865](#)

Line affected: L21 · Effort: 1h · Introduced: 2 months ago

Open Not assigned No tags

Where is the issue? Why is this an issue? How can I fix it? Activity More info

testing-fincore.backend > deployment-fn_bpkb.yaml

```
15 apiVersion: v1
16 kind: Pod
17 metadata:
18   name: example-pod
19 spec: # Noncompliant
20   containers:
21     - name: example-container
22       image: nginx
```

Open in IDE See all issues in this file

Software qualities impacted

Security Medium

Maintainability Medium

Clean code attribute

Intentionality | Not complete

Bind this resource's automated service account to RBAC or disable automounting.

Service account permissions should be restricted to [kubernetes:S6865](#)

Line affected: L21 · Effort: 1h · Introduced: 2 months ago

Open Not assigned No tags

Where is the issue? Why is this an issue? How can I fix it? Activity More info

In this example, the service account token is mounted in the pod `example-pod` by default, but is unnecessary for the pod and its service(s) to function correctly.

```
apiVersion: v1
kind: Pod
metadata:
  name: example-pod
spec: # Noncompliant
  containers:
    - name: example-container
      image: nginx
```

In this example, the service account token is mounted in the pod `example-pod` and is necessary, for example because it allows a third-party service to authenticate with the Kubernetes API. However, no specific permissions are granted to the service account:

```
apiVersion: v1
kind: Pod
metadata:
  name: example-pod
spec:
  serviceAccountName: example-sa # Noncompliant
  containers:
```